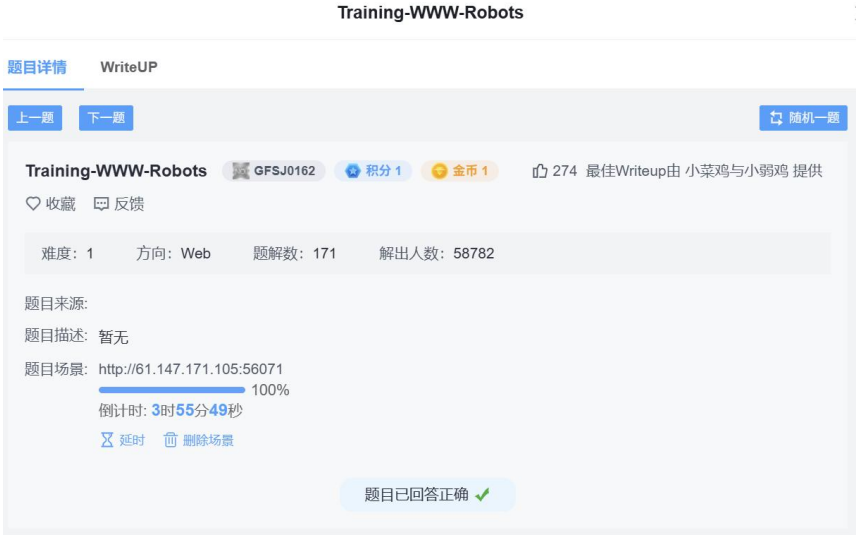
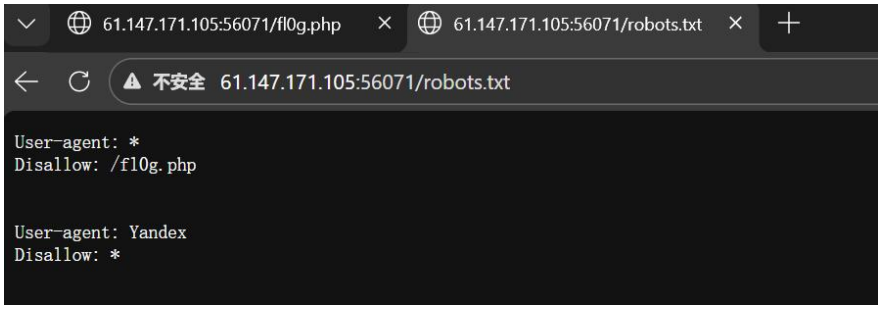


下载附件得到场景

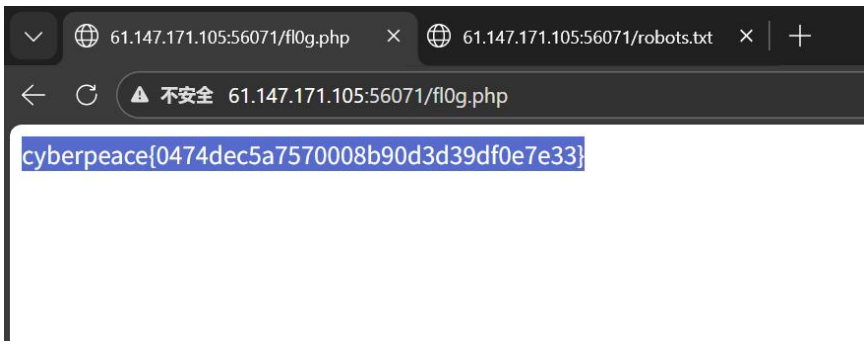


然后复制链接 http://61.147.171.105:56071 加上/robots.txt，即 http://61.147.171.105:56071/robots.txt 按下回车访问，（该文件是网站告诉搜索引擎那些以爬取、那些禁止爬取），

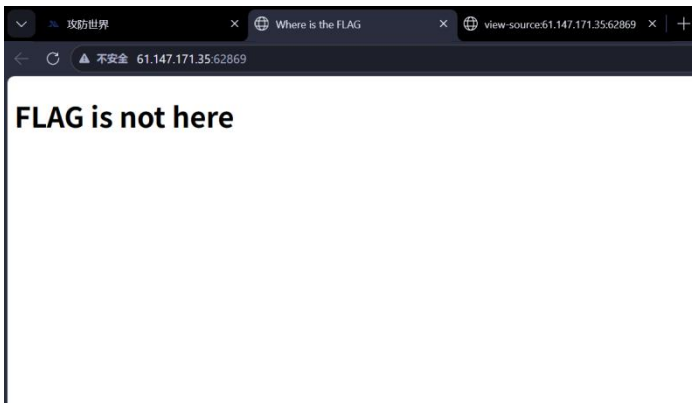
从 robots.txt 里找到 Disallow: /f10g.php

用/f10g.php 替换/robots.txt 得 http://61.147.171.105:56071/f10g.php

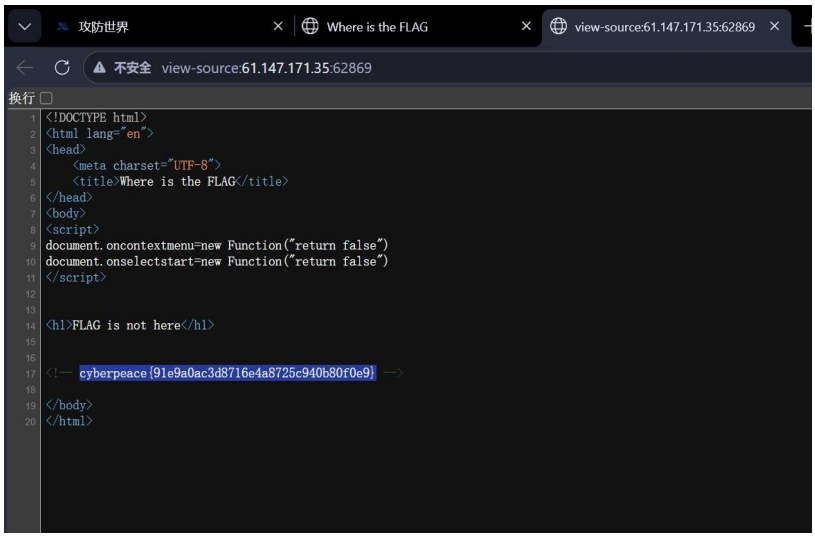
User-agent: Yandex 和 Dissallow: *是干扰项，是搜索引擎爬虫的规则限制，和解题无关

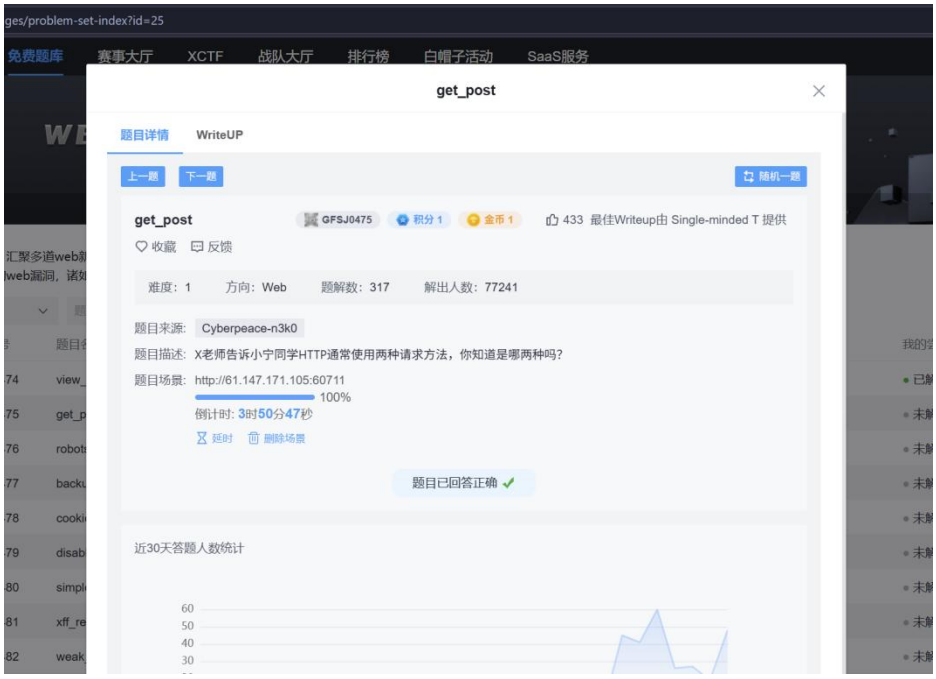


1、打开链接



2、按下快捷键 CTRL+u，页面会直接跳转到页面源代码页面，即可找到 flag





该题核心考点是 **HTTP 的 GET 与 POST 两种请求方法的联合使用**

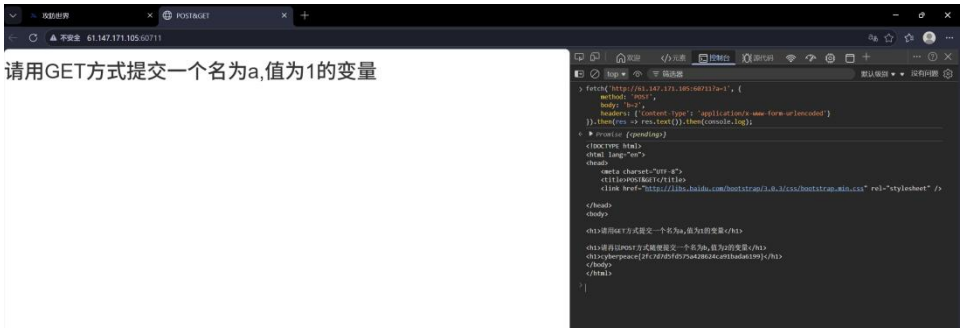
- **GET 请求**：参数通过 URL 传递，格式为网址?参数名=参数值。
- **POST 请求**：参数通过请求体传递，需在请求中单独设置。

1、**打开开发者工具**：访问题目场景后，按 F12 或 Ctrl+Shift+I，切换到 Console（控制台）标签页。

2、**执行 AJAX 请求**：输入以下 JavaScript 代码，同时构造 GET 和 POST 请求，按回车执行：

关键补充说明：

题目对 GET 和 POST 的**参数名、参数值无固定要求**，只需确保同时传递两种请求的参数即可。



该题核心考点是 robots.txt 协议的访问与解读。robots.txt 是网站根目录下的一个文本文件，用于告知搜索引擎哪些内容可被抓取，CTF 中常用来隐藏敏感路径或 Flag。

1、打开浏览器，在地址栏输入拼接后的 URL：http://61.147.171.105:54741/robots.txt（规则：目标网址 + /robots.txt）

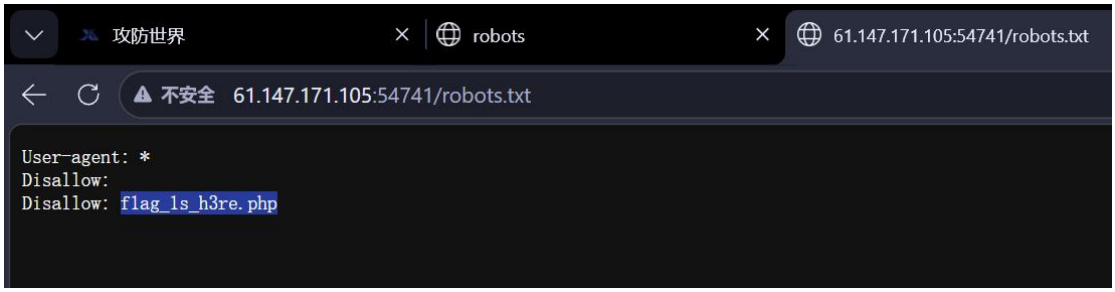
2、**从 robots.txt 中找线索**通常里面会有类似这样的内容：

plaintext

```
User-agent: *

Disallow: /xxx_xxx
```

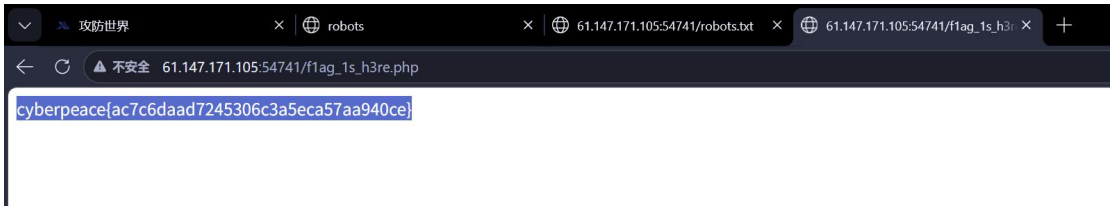
这个被禁止访问的路径 /xxx_xxx 就是藏 flag 的地方。



3、访问隐藏路径：

把刚才的路径拼到网址后面，比如：

http://61.147.171.105:54741/xxx_xxx



关键补充说明

1. **robots.txt 的标准位置**：必须位于网站**根目录**，文件名严格区分大小写（只能是 robots.txt）。
2. **常见出题形式**：
1. 形式 1：robots.txt 中直接写有 Flag。
2. 形式 2：robots.txt 中通过 Disallow 字段标注禁止访问的路径（如 Disallow: /flag），访问该路径即可拿到 Flag。

[HCTF 2018]WarmUp

1、打开后得到滑稽笑脸图片，然后查看源代码，看注释得到 source.php，然后查看得到一大串代码，然后分析代码。

2、

```php
public static function checkFile(&$page)
{
    $whitelist = ["source"=>"source.php","hint"=>"hint.php"];
    // 1. 基础校验：$page 必须存在且是字符串
    if (! isset($page) || !is_string($page)) {
        echo "you can't see it";
        return false;
    }

    // 2. 白名单直接匹配
    if (in_array($page, $whitelist)) {
        return true;
    }

    // 3. 截取问号前的部分，再匹配白名单
    $_page = mb_substr(
        $page,
        0,
        mb_strpos($page . '?', '?')
    );
    if (in_array($_page, $whitelist)) {
        return true;
    }
```

```php
    // 4. URL解码后，再截取问号前的部分，匹配白名单
    $_page = urldecode($page);
    $_page = mb_substr(
        $_page,
        0,
        mb_strpos($_page . '?', '?')
    );
    if (in_array($_page, $whitelist)) {
        return true;
    }

    echo "you can't see it";
    return false;
}
```